

合约安全审计报告

IronBrother / CrudeTrust - BSC Mainnet 合约快照

项目	内容
审计日期	2026-05-19 / Asia/Shanghai
审计范围	contracts/IronBrother.sol; BSC Mainnet proxy 与关键运行配置
主网 Proxy	0x25cCc567C5a72Bb164d0e759 69ff6141a7d735E3
链上实现地址	0x7dd8bc3bA3Be923dD73c5DF1 D2F2cF6961bd4ED6
USDT	0x55d398326f99059fF7754852 46999027B3197955
验证区块	99,196,722

结论摘要	未发现普通用户可直接盗取合约 USDT 的简单重入或任意转账漏洞；但存在 4 个需要优先处理的合约级风险：主网实现地址与仓库部署记录不一致、自动提现模式下奖励池余额为 0、推荐关系可形成环并影响动态奖励、Super Admin 权限过于集中。
------	---

1. 审计方法与限制

本报告基于本地源码静态审查、Hardhat 编译与合约专项测试、BSC Mainnet 只读链上查询形成。未进行私钥验证、未执行主网写交易、未部署新实现、未修改合约代码。

- 静态范围：contracts/IronBrother.sol 的资金、权限、升级、注册推荐、收益结算与提现路径。
- 动态验证：读取主网 proxy、ERC1967 implementation slot、关键配置、角色、合约 USDT 余额与账面奖励余额。
- 工具限制：本机未安装 Slither，因此未纳入 Slither 自动扫描结果；报告以人工审计和 Hardhat 测试为准。

2. 主网运行快照

字段	当前值
Proxy	0x25cCc567C5a72Bb164d0e759 69ff6141a7d735E3
Implementation (live slot)	0x7dd8bc3bA3Be923dD73c5DF1 D2F2cF6961bd4ED6
Implementation (deployments/bsc.json)	0x9a7B05b3e8C9F41BAec9b8a 1Af94d7440246ba4

字段	当前值
withdrawalApprovalRequired	false - 新提现由合约奖励池自动打款
合约 USDT 余额	0.0 USDT
totalRewardBalance	181.005 USDT
totalPendingWithdrawalAmount	0.0 USDT
totalUsers	39
totalDepositedAmount	20,600.4 USDT
totalWithdrawnAmount	0.0 USDT

注：上述主网数据来自 2026-05-19 读取的 BSC Mainnet 区块 99,196,722。

3. 发现汇总

编号	等级	问题	影响面	建议
IB-01	High	仓库部署记录与主网 implementation 不一致	升级/运维真实性	立即核对升级来源并更新部署元数据
IB-02	High	自动提现模式下合约 USDT 余额为 0	用户提现可用性	充值奖励池或临时开启审批模式
IB-03	High	推荐关系可形成环，动态奖励可能重复经过同一地址	奖励完整性	增加推荐链环检测并迁移异常关系
IB-04	Medium-High	Super Admin 权限覆盖升级、资金提取和参数修改	权限/治理	迁移多签或拆分权限
IB-05	Medium	withdrawContractFunds 可提走所有奖励池余额	偿付能力	限制只可提盈余
IB-06	Low-Medium	未来 day 也可能被视为动态奖励已关闭	逻辑严谨性	改为仅允许 day < currentDay

4. 详细发现

IB-01 - 主网 implementation 与仓库部署记录不一致

High。链上 ERC1967 implementation slot 返回 0x7dd8bc3bA3Be923dD73c5DF1D2F2cF6961bd4ED6，但 deployments/bsc.json 和 .openzeppelin/bsc.json 仍记录 0x9a7B05b3e8C9F41BAaec9b8a1Af94d7440246ba4。风险：无法仅凭仓库部署文件确认当前主网运行代码是否与本地源码一致；后续升级、回滚和事故排查会出现证据断层。建议：立即从 BscScan 或编译产物验证 0x7dd8... 的源码/字节码；补齐升级交易、implementation、manifest 与部署 JSON；把“读取 implementation slot + 字节码比对”设为每次上线后验收项。

IB-02 - 自动提现模式下奖励池余额不足

High。合约当前 withdrawalApprovalRequired=false，requestWithdrawRewards 会要求 `usdt.balanceOf(address(this)) >= amount`，然后由合约直接 `safeTransfer` 给用户。主网合约 USDT 余额为 0.0，但 `totalRewardBalance` 为 181.005。风险：用户账面奖励可见但无法自动提现，交易会 revert 为 `insufficient payout balance`。建议：短期向合约奖励池充值至少覆盖 `totalRewardBalance`；如果不能立即补足，临时 `setWithdrawalApprovalRequired(true)`，让 Admin 审批出币；中期增加偿付率监控。

IB-03 - 推荐关系可形成环

High。`_bindReferrer()` 只禁止 `referrer == user`；如果 A 先把 B 自动注册为无上级账号，B 后续仍可绑定 A 为上级，形成 `A <-> B`。动态奖励结算最多沿 `referrer` 链走 40 代，环会让同一地址在一次结算中被重复访问。风险：奖励分配可能偏离真实层级；在双方有效代数足够时，可重复向环内地址累计动态奖励。建议：绑定推荐人时向上遍历 `referrer` 链，发现 `newReferrer` 的上级链包含 `user` 时 revert；同时输出现有链上关系巡检脚本，定位已经形成的环。

IB-04 - Super Admin 权限高度集中

Medium-High。`DEFAULT_ADMIN_ROLE` 能升级 UUPS 实现、设置 Admin/Manager、修改收款地址、改提现模式、改收益和有效门槛、暂停/恢复合约，并可 `withdrawContractFunds` 提走合约 USDT。风险：单私钥泄露或误操作即可改变资金路径和核心业务规则。当前 0xAC25...1bD8 同时拥有 Admin 与 Manager。建议：将 `DEFAULT_ADMIN_ROLE` 迁移到多签；将升级、资金提取、运营结算、参数调整拆成独立角色；高风险操作增加 `timelock` 或二次确认。

IB-05 - 管理员可提走全部奖励池余额

Medium。`withdrawContractFunds` 只检查合约 USDT 余额，不检查用户账面奖励负债 `totalRewardBalance`。即使自动提现依赖奖励池，也可以由 Super Admin 提走全部余额。风险：奖励池被提空后，用户提现重新失败；账面奖励和实际可兑付余额脱钩。建议：增加可提取上限：`availableSurplus = usdt.balanceOf(address(this)) - totalRewardBalance - totalPendingWithdrawalAmount`；或者只允许在审批模式/暂停状态下提取。

IB-06 - 动态奖励关闭日判断不严谨

Low-Medium。`_isDynamicRewardDayClosed(day)` 返回 `day < currentDay || day > currentDay * 2`，未来很远的 `day` 会被视为已关闭。当前实际影响有限，因为未来 `day` 通常没有 `dailyStakeVolume`。建议：将条件收敛为 `day < currentDay`；如需兼容测试周期，测试网通过专门配置或脚本处理，不应让主网逻辑接受未来日。

5. 未发现的高危模式

- 普通用户不能直接调用 `withdrawContractFunds`；该路径受 `onlySuperAdmin` 限制。
- 主要资金转账路径使用 `SafeERC20`，提现、充值、提取均带 `nonReentrant`。
- UUPS 升级入口 `_authorizeUpgrade` 受 `onlySuperAdmin` 限制；没有公开任意 `delegatecall`。
- 静态收益 `settleStake` 以订单 `settled` 标记防止重复结算；动态奖励以 `dynamicRewardSettled[user][day]` 防止同一 `source/day` 重复结算。

6. 建议修复顺序

顺序	时限	动作
1	立即	确认主网 <code>implementation 0x7dd8...</code> 的源码/字节码，补齐部署记录。
2	立即	解决提现偿付：充值奖励池或开启审批模式。
3	短期	增加推荐关系环检测，并巡检主网已存在关系。
4	短期	限制 <code>withdrawContractFunds</code> 只能提盈余。
5	中期	把 Super Admin 迁移到多签/时间锁，并拆分资金与运营权限。
6	中期	修正 <code>_isDynamicRewardDayClosed</code> 条件并补充单元测试。

7. 验证记录

检查项	结果	说明
<code>npx hardhat compile</code>	通过	Nothing to compile
<code>npx hardhat test test\IronBrother.test.cjs test\dynamicRewards.test.cjs</code>	通过	23 passing
主网配置读取	通过	区块 99,196,722；读取 <code>proxy</code> 、 <code>implementation</code> 、角色、余额、关键参数
Slither	未执行	本机未安装 <code>slither</code> 命令

附录 A - 关键源码证据

证据	位置	含义
UUPS 升级授权	contracts/IronBrother.sol:247	_authorizeUpgrade(address newImplementation) internal override onlySuperAdmin
充值收款轮转	contracts/IronBrother.sol:265-266	deposit 直接 safeTransferFrom 到 depositReceivers，不进入合约余额
审批提现	contracts/IronBrother.sol:376-396	Admin 审批时从 msg.sender safeTransferFrom 给用户和 feeReceiver
自动提现	contracts/IronBrother.sol:423-456	关闭审批时从合约余额 safeTransfer 给用户
奖励池充值	contracts/IronBrother.sol:462-465	fundRewards 从调用者转 USDT 到合约
管理员提走资金	contracts/IronBrother.sol:468-474	onlySuperAdmin 可提走合约 USDT
推荐绑定	contracts/IronBrother.sol:892-905	_bindReferrer 仅禁止 self referrer，未检测环
动态奖励结算	contracts/IronBrother.sol:833-843	沿 referrer 链按 eligibleGeneration 计奖
关闭日判断	contracts/IronBrother.sol:975-977	day < currentDay day > currentDay * 2

本报告为指定代码与链上快照下的安全审计结论，不等同于完整形式化验证或法律保证。后续任何合约升级、参数变更、角色变更、部署文件更新都会改变风险状态。